

****NEWSLETTER N. 519 of March 7, 2024****

****Data breach: the Authority fines UniCredit 2.8 million euros****

****App for diabetics: the Privacy Authority fines a medical device company****

****Speed cameras, Privacy Authority: favorable opinion to the Ministry of Infrastructure and Transport****

****EU privacy authorities will have greater autonomy against non-EU companies****

****Data breach: the Authority fines UniCredit 2.8 million euros*****

Fines of 800,000 euros also imposed on the company tasked with conducting security tests

*The measure against UniCredit has been challenged before the Court of Milan, which ordered the suspension of the effectiveness of the ancillary sanction of publishing the measure on the Authority's website with order no. 1927 of March 28, 2024 (RG no. 10477/202). The publication of the measure against NTT Data has been suspended in relation to what was established with the ruling concerning UniCredit.

Banks must adopt all necessary technical-organizational and security measures to prevent their customers' data from being unlawfully accessed. This was stated by the Privacy Authority when sanctioning UniCredit bank for a personal data breach that occurred in 2018, which involved thousands of customers and former customers.

From the checks carried out by the Authority - following the receipt of the data breach notification from the bank - it emerged that the breach occurred due to a massive cyber attack perpetrated by cybercriminals on the mobile banking portal. The attack led to the unlawful acquisition of the name, surname, tax code, and identification code of approximately 778,000 customers and former customers, and for over 6,800 of the "attacked" customers, it also involved the identification of the access PIN to the portal. The data was made available in the HTTP response provided by the bank's systems to the browser of anyone attempting to access, even unsuccessfully, the mobile banking portal.

During the complex investigative activity, the Authority identified several violations of privacy regulations. In particular, the Authority found that the bank had not adopted technical and security measures capable of effectively countering potential cyber attacks and preventing its customers from using weak PINs (such as those composed of number sequences or coinciding with the date of birth). In determining the amount of the fine at 2 million and 800 thousand euros, the Authority considered the high number of individuals involved in the personal data breach, the severity of the breach, and the bank's economic capacity. The timely adoption of corrective measures, the information and support initiatives undertaken towards customers, and the fact that the breach did not concern banking data were considered mitigating factors.

With the adoption of a second measure, the Authority also intervened against NTT Data Italia, sanctioning the company with a fine of 800,000 euros. From the checks carried out by the Authority, it particularly emerged that NTT Data Italia had communicated to UniCredit the occurrence of the personal data breach of its customers after the deadline set by the Regulation and only after the bank became aware of it through its internal monitoring systems.

Furthermore, NTT Data Italia had subcontracted the execution of vulnerability assessment and penetration testing activities to another company, without prior authorization from the bank as the data controller, which had expressly prohibited the outsourcing of such activities to third parties.

****App for diabetics: the Privacy Authority fines a medical device company****

Had sent emails in plain text to hundreds of diabetic patients

The Privacy Authority has imposed two fines totaling 300,000 euros on a well-known company that produces medical devices for monitoring, preventing, and treating various diseases. The first, of 250,000 euros, was imposed on the company for sending some emails with the addresses, in plain text, of hundreds of recipients, diabetic patients, who used its app for measuring glucose levels. The other fine of 50,000 euros was for failing to provide complete information to patients using healthcare services.

During the investigation, it emerged that, when sending emails regarding an update of the application, thus a service communication, the inclusion of email addresses in the "cc" field instead of "bcc" allowed all recipients to see the addresses contained in the mailing list, resulting in the company

communicating extremely sensitive personal data, such as health-related information, to unauthorized third parties.

The incident also highlighted the company's failure to adopt adequate technical and organizational measures to reduce the risk of a

****Data Breach.****

From the investigations conducted by the Guarantor to verify the compliance of the processing carried out through the services offered to users, other violations have also emerged that have been considered separately for the purpose of quantifying the administrative sanction. In particular, the legal basis under which the communication of personal data of patients who intended to link their personal account with that of the healthcare professional, as the data controller, was not indicated in the information notice, in violation of the principle of fairness and transparency.

****Speed Cameras, Privacy Guarantor: Favorable Opinion to the Ministry of Infrastructure****

Images and videos sent to the motorist only upon request

The Guarantor has approved the draft decree of the Minister of Infrastructure and Transport, in agreement with the Minister of the Interior, regarding the placement and use of speed cameras. In the version of the draft under examination by the Authority, the observations provided by the Guarantor's Office during the investigation were taken into account to make the decree compliant with privacy regulations.

As requested by the Guarantor, the images that constitute evidence for violations of the highway code must not be sent to the residence of the vehicle owner along with the violation notice. The photographic or video documentation must indeed be made available to the recipient of the notice only upon their request, ensuring, in any case, that third parties and license plates of any other vehicles captured are appropriately obscured or rendered unrecognizable.

In respect of motorists' privacy, the use of speed detection systems that capture the vehicle from the front is also permitted, but only if equipped with a function that automatically obscures the images of the people on board. The devices and recording systems, moreover, while being able to continuously monitor traffic, will store images only in the event of a violation. Finally, the decree defines the retention periods for the images and videos collected by the competent road police authorities responsible for issuing sanctions. These are retained for the strictly necessary period for the application of fines and the resolution of any disputes, in accordance with the provisions of Title VI of the New Highway Code.

****EU Privacy Authorities Will Have Greater Autonomy Against Non-EU Companies****

Clarified by the Committee of Guarantees the notion of main establishment

When a non-European company has an establishment in the member countries of the European Union, but decisions regarding the purposes and means of processing are made outside the EU, the mechanism of the so-called "One-Stop-Shop" does not apply. In these cases, any privacy authority of a member country can act autonomously to protect the rights of its citizens and intervene directly with the data controller.

This important decision was made by the European Data Protection Board (EDPB) on February 13 by adopting an opinion on the notion of "main establishment" and the criteria for applying the One-Stop-Shop mechanism, according to which the lead supervisory authority acts as the main contact point for the data controller or processor (while the concerned supervisory authorities act as the main contact point for data subjects in their member state) and is responsible for conducting the cooperation process with other Authorities.

The notion of main establishment is one of the cornerstones of the One-Stop-Shop and is essential for determining which, if applicable, is the lead supervisory authority in cases of data protection involving multiple member states. The Committee clarified that the "central administration location" of a data controller in the EU can be considered "main establishment" only if it is where decisions are made regarding the purposes and means of processing personal data and if it has the power to implement such decisions. Only in this case, therefore, does the One-Stop-Shop mechanism apply.

When decisions regarding the purposes and means of processing are made outside the EU, the "central administration location" cannot be considered the main establishment of the data controller in

the Union nor should the One-Stop-Shop apply, and therefore any national Authority can intervene directly with the data controller. Furthermore, it is also the responsibility of the data controller, the opinion further clarifies, to demonstrate that decisions regarding the purposes and means of processing personal data were made in the EU country where the main establishment is located, and its conclusions can still be challenged by the data protection authorities.

****THE ACTIVITIES OF THE GUARANTOR - FOR THOSE WHO WANT TO KNOW MORE****

The most important interventions and measures recently adopted by the Authority

Telemarketing: The Privacy Authority sanctions Enel

Energy – Press Release of February 29, 2024

*The measure has been challenged before the Court of Rome, which ordered the suspension of the executive effectiveness of the prescriptive and sanctioning measure by order of July 10, 2024.

Employee emails, the Privacy Authority initiates a public consultation – Press Release of February 27, 2024

Banks: from the Privacy Authority and ABI the first “snapshot” of the personal data protection officer in the banking sector – Press Release of February 20, 2024

NEWSLETTER of the Authority for the protection of personal data (Registered at the Court of Rome No. 654 of November 28, 2002).

Responsible Director: Baldo Meo.

Management and Editorial Office: Authority for the protection of personal data, Piazza Venezia, No. 11 - 00187 Rome.

Tel: 06.69677.2751 - Fax: 06.69677.3785

The newsletter is available on the website www.gpdp.it